

ISO 27005

Le guide tactique

12/02/2026

© 2026 Clément Wencker. Tous droits réservés.



Disclaimer

La méthodologie et les conseils présentés dans cet ouvrage sont le fruit de mon expérience professionnelle et éducative dans le but de vulgariser la norme.

La cybersécurité est un domaine complexe dépendant de contextes spécifiques. Je ne saurais être tenu responsable des erreurs, omissions, ou des conséquences (directes ou indirectes, financières ou techniques) résultant de l'application des informations contenues dans ce guide. Le risque zéro n'existe pas, et ce livre ne constitue pas une garantie de résultat ou de certification.

J'ai écrit cet eBook pour une raison simple : la sécurité offensive s'apprend en pratiquant dans des labs, mais la GRC s'apprend mieux en prenant de la hauteur et en vulgarisant.

De ce fait, j'ai vu peu de ressources qui vulgarisent 'simplement' la méthode de gestion des risques et j'ai donc utilisé l'intelligence artificielle en complément des normes officielles ISO/IEC pour m'aider à décortiquer ces concepts parfois trop compliqués à visionner.

Cet ebook est le résultat de ce travail personnel. C'est le guide que j'ai construit initialement pour moi-même, pour le passage de la certification chez PECB.

TABLE DES MATIERES

Disclaimer	2
<i>Explications de la norme ISO 27005.....</i>	5
Introduction	5
<i>Chapitre 1 : Le cadrage</i>	6
1. Démystifier le Vocabulaire	6
L'Actif.....	6
La Menace.....	6
La Vulnérabilité	7
2. L'Équation du Risque.....	7
Risque vs Problème.....	7
3. L'Alignement ISO 27001	8
4. Construire votre Règle	8
Les Critères d'Impact	8
Les Critères de Vraisemblance (La Probabilité).....	9
Les Critères d'Acceptation (L'Appétence au Risque).....	9

5. Résumé du Chapitre.....	9
Chapitre 2 : L'identification des risques	10
1. Choisissez votre approche	10
Option A : L'approche par les Actifs (micro).....	10
Option B : L'approche par les Événements (macro).....	10
2. L'Inventaire des Actifs.....	11
3. Identifier les Menaces : Utilisez les "Cheat Sheet"	12
4. Identifier les Vulnérabilités : Où est la faille ?	13
5. Formaliser le Scénario de Risque.....	13
Exemple 1 (Ransomware) :	13
Exemple 2 (Vol) :	14
6. Résumé du Chapitre.....	14
Chapitre 3 : L'Analyse et l'Évaluation du risque	15
1. L'Analyse : Sortez les calculatrices (ou pas)	15
L'approche Quantitative	15
L'approche Qualitative	15
Le Calcul du Niveau de Risque :	16
2. L'Évaluation	16
La Matrice de Chaleur (Heatmap).....	17
La Décision binaire.....	17
Le Rôle du Propriétaire du Risque (Risk Owner)	17
3. Impact vs Probabilité.....	18
4. Livrable : Le Registre des Risques Classé	18
Analyse immédiate :	18
Chapitre 4 : Le Traitement du Risque	19
1. Les 4 Options Stratégiques	19
Option A : Modification du Risque (La Réduction).....	19
Option B : Partage du Risque (Le Transfert).....	19
Option C : Évitement du Risque (La Solution Radicale)	20
Option D : Maintien du Risque (L'Acceptation)	20
2. Sélectionner les Mesures (Annexe A)	20
Le Plan de Traitement des Risques (PTR).....	21
3. Le Risque Résiduel	21
La mécanique de calcul :	21
L'Acceptation Formelle :	21
4. Le Lien avec la SoA (Déclaration d'Applicabilité)	22
Résumé du Chapitre.....	22

Chapitre 5 : Communication et Surveillance	23
1. Communication et Consultation	23
Pourquoi consulter ?	23
La Règle d'Autorité.....	23
2. La Surveillance.....	24
KRI vs KPI : Ne confondez pas	24
Exemples de KRI :	24
3. La Revue	24
A. La Revue Planifiée (Le Minimum Syndical).....	25
B. Le Changement Majeur (Major Change)	25
C. L'Incident Majeur	25
D. Le Changement de Contexte Externe	25
4. Le Reporting à la Direction	26
Conclusion	27
Liste des documents à produire	28
Glossaire.....	32
A.....	32
C.....	33
D	33
E.....	33
I.....	34
K.....	34
M.....	34
P	35
Q	35
R.....	35
S	36
V.....	36

EXPLICATIONS DE LA NORME ISO 27005

Introduction

Personne ne lit la norme ISO/IEC 27005 pour le plaisir. C'est un document aride, théorique, rempli de définitions circulaires et de diagrammes abstraits. Pourtant, si vous tenez ce livre, c'est que vous avez compris une vérité fondamentale de la cybersécurité : la technique ne suffit plus. Vous pouvez avoir les meilleurs pare-feux du monde, si vous protégez le mauvais serveur, vous avez perdu.

Vous pouvez avoir le meilleur antivirus, si vous ignorez le risque juridique du RGPD, vous ferez faillite. La gestion des risques n'est pas une option administrative pour faire plaisir à un auditeur. C'est le moteur de la sécurité de l'information. C'est la seule langue que comprend votre Direction Générale : celle de l'argent, de la probabilité et de l'impact.

Cet eBook est conçu pour deux types de personnes :

- Le candidat à l'examen (Risk Manager / Lead Implementer) qui veut les points clés, les pièges à éviter et la logique de l'analyse de risques.
- L'étudiant en cybersécurité qui cherche à comprendre de manière plus approfondie la gestion des risques au sein d'une organisation.

CHAPITRE 1 : LE CADRAGE

Si vous commencez votre gestion des risques en listant des problèmes techniques, vous avez déjà échoué. La gestion des risques selon l'ISO 27005 n'est pas un exercice technique, c'est un exercice de gouvernance. C'est une traduction : vous devez traduire des peurs techniques (virus, pannes) en langage business (pertes financières, arrêts de production).

Avant de jouer, il faut définir les règles. Sans règles, votre analyse sera subjective, incohérente et rejetée par l'auditeur. Ce premier chapitre couvre l'étape cruciale de l'Établissement du Contexte (Clause 6 de l'ISO 27005).

1. Démystifier le Vocabulaire

L'examen et l'auditeur ne toléreront aucune confusion. La précision des termes est votre première arme. Oubliez le langage courant, voici le langage de la norme. Le Trio Infernal : Actif, Menace, Vulnérabilité

Un risque n'existe que si ces trois éléments sont réunis. C'est une équation mécanique.

L'Actif

C'est ce qui a de la valeur. Si vous le perdez, l'entreprise souffre.

- La nuance vitale : L'ISO 27005 distingue deux niveaux.
 - Actifs Primaires : Ce sont les informations et les processus métier (ex : "La liste des clients", "Le processus de facturation"). C'est ce qui a de la valeur.
 - Actifs Supports : Ce sont les outils qui hébergent les actifs primaires (ex : "Serveur SQL", "PC du comptable", "Application SAP").
- L'erreur classique : Faire une analyse de risques uniquement sur les actifs supports ("Mon serveur peut tomber en panne"). On s'en fiche du serveur. On s'intéresse à l'arrêt de la facturation causé par la panne du serveur.

La Menace

C'est la cause potentielle de l'incident. Elle est externe à l'actif. Vous ne la contrôlez pas, vous la subissez.

- Exemples : Un groupe de hackers (Ransomware), une inondation, une erreur de saisie d'un stagiaire, une panne disque dur.
- Règle d'or : Une menace peut être intentionnelle (attaque) ou accidentelle (naturelle/erreur).

La Vulnérabilité

C'est la faiblesse interne. C'est la "porte ouverte" que la menace va utiliser. C'est le seul élément que vous pouvez corriger directement.

- Exemples : Un Windows non mis à jour (faille technique), une salle serveur au sous-sol en zone inondable (faille physique), un employé non formé (faille humaine).

2. L'Équation du Risque

Une **Menace** exploite une **Vulnérabilité** sur un **Actif**, entraînant un **Impact**.
Exemple Concret :

La pluie (**Menace**) tombe sur un toit percé (**Vulnérabilité**) de l'entrepôt (**Actif Support**), mouillant le stock (**Actif Primaire**) et causant une perte financière (**Impact**).

Si vous réparez le toit (**Suppression de la vulnérabilité**), la pluie (**Menace**) est toujours là, mais le **Risque disparaît**.

Risque vs Problème

Ne confondez jamais les deux.

- Risque : C'est de l'incertitude. C'est du futur. "Le disque pourrait casser." On gère le risque par la probabilité.
- Problème (ou Incident) : C'est un fait. C'est du passé ou présent. "Le disque est cassé." On gère l'incident par la réaction.

L'ISO 27005 sert à anticiper le futur, pas à documenter le passé.

3. L'Alignement ISO 27001

Vous ne faites pas de la gestion des risques pour le plaisir. Vous le faites pour répondre à une exigence précise : l'article 6.1.2 de l'ISO 27001. La norme ISO 27001 est la "Loi". Elle dit : "L'organisme DOIT définir et appliquer un processus d'appréciation des risques."

La norme ISO 27005 est le "Guide". Elle dit : "Voici une méthode structurée pour satisfaire l'exigence 6.1.2."

Le contrat est clair : Votre analyse de risques doit produire deux choses pour l'auditeur :

- Une liste de risques priorisée : Quels sont les vrais dangers ?
- Une justification des dépenses : Pourquoi acheter un pare-feu à 10 000 € ? Parce qu'il réduit le Risque n°4 qui a un impact potentiel de 500 000 €.
- Si votre analyse de risques ne permet pas de prendre des décisions budgétaires, elle est inutile. C'est un outil d'aide à la décision pour la Direction, pas un document technique pour le service informatique.

4. Construire votre Règle

Avant de mesurer quoi que ce soit, vous devez fabriquer votre règle. Qu'est-ce qui est "Grave" pour votre entreprise ?

Si vous êtes une startup, une perte de 10 000 € est catastrophique. Si vous êtes Google, c'est une erreur d'arrondi. L'ISO 27005 exige que vous définissiez vos Critères de Risque (Risk Criteria).

Vous devez définir trois échelles AVANT de commencer l'identification.

Les Critères d'Impact

Ne notez pas au hasard. Définissez ce que signifient 1, 2, 3, 4. Utilisez plusieurs dimensions : Financier, Image, Légal, Opérationnel. Exemple d'échelle d'impact (à adapter au contexte) :

- Niveau 1 (Faible) : Perte < 1 000 €. Pas d'arrêt de service. Pas d'impact médiatique.
- Niveau 2 (Moyen) : Perte < 10 000 €. Arrêt < 4h. Plainte client isolée.
- Niveau 3 (Fort) : Perte < 100 000 €. Arrêt < 24h. Article dans la presse locale. Infraction mineure au RGPD.
- Niveau 4 (Critique) : Perte > 100 000 €. Arrêt > 24h. Scandale national. Sanction pénale ou administrative lourde.
- Soyez quantitatifs dès que possible. "Impact fort" ne veut rien dire. "Perte de 10% du CA" est indiscutable.

Les Critères de Vraisemblance (La Probabilité)

N'essayez pas de calculer des pourcentages ("Il y a 0.04% de chance"). Raisonniez en fréquence.

Exemple d'échelle de vraisemblance :

- Niveau 1 (Improbable) : Jamais arrivé dans le secteur. Théorique. (1 fois tous les 10 ans).
- Niveau 2 (Possible) : Déjà arrivé chez des concurrents ou une fois dans l'histoire de l'entreprise. (1 fois tous les 3 ans).
- Niveau 3 (Probable) : Arrive régulièrement. (1 fois par an).
- Niveau 4 (Très fréquent) : C'est un problème récurrent. (Plusieurs fois par mois).

Les Critères d'Acceptation (L'Appétence au Risque)

Le risque zéro n'existe pas. L'entreprise doit définir jusqu'où elle accepte de souffrir.

Ceci se matérialise par une Matrice (Heatmap). Vous croisez l'Impact et la Vraisemblance.

- Si Impact (4) x Vraisemblance (4) = 16 -> Zone Rouge (Inacceptable). Il FAUT traiter immédiatement.
- Si Impact (2) x Vraisemblance (2) = 4 -> Zone Verte (Acceptable). On ne fait rien, on surveille.
- Qui décide des critères ?
- Ce n'est JAMAIS le RSSI ou le Risk Manager qui définit si une perte de 100k€ est grave.
- C'est la Direction Générale (le Top Management).
- Votre rôle est de proposer les échelles, leur rôle est de les valider. Sans signature de la direction sur ces critères, votre analyse de risques n'a aucune valeur légale ou normative.

5. Résumé du Chapitre

Vous avez maintenant posé les fondations :

- Vous parlez le bon langage : Menace + Vulnérabilité + Actif = Risque.
- Vous savez pourquoi vous le faites : Pour satisfaire l'ISO 27001 (6.1.2) et justifier le budget.
- Vous avez calibré vos instruments : Vous avez des échelles d'Impact et de Vraisemblance chiffrées et validées par le Top-Mangement.

CHAPITRE 2 : L'IDENTIFICATION DES RISQUES

L'identification des risques est l'étape la plus critique. Si vous ratez un risque ici, vous ne l'analyserez pas, vous ne le traiterez pas, et il vous frappera dans le dos.

L'ignorance n'est pas une défense lors d'un audit (ni lors d'un piratage). Oubliez le brainstorming chaotique autour d'une machine à café. L'ISO 27005 exige de la méthode. En 2022, la norme a clarifié deux approches distinctes.

1. Choisissez votre approche

Avant de lister n'importe quoi, vous devez décider comment vous allez parcourir votre organisation. Il y a deux écoles.

Option A : L'approche par les Actifs (micro)

C'est la méthode historique, la plus rigoureuse, celle que les auditeurs adorent pour sa précision.

- La logique : Vous listez tout ce que vous possédez (Actifs). Pour chaque actif, vous vous demandez "Qu'est-ce qui peut lui arriver ?".
- Avantage : Exhaustivité. Vous n'oubliez rien.
- Inconvénient : C'est long. Très long. Vous risquez de vous noyer dans les détails techniques et de perdre la vision business.
- Pour qui ? Les admins sys, les RSSI rigoureux, les premières certifications ISO 27001.

Option B : L'approche par les Événements (macro)

Mise en avant par la version 2022. On part du scénario redouté.

- La logique : Vous partez des peurs de la direction. "On a peur du Ransomware", "On a peur de la fraude au président". Ensuite, vous regardez quels actifs sont concernés.
- Avantage : Parle immédiatement au Business. Rapide.
- Inconvénient : Vous risquez de passer à côté de risques "ennuyeux" mais réels (ex : la panne de clim).
- Pour qui ? Les révisions annuelles, les présentations au ComEx.

Pour votre première analyse, utilisez l'approche par les Actifs. C'est laborieux, mais c'est la seule façon de construire un socle solide. C'est celle que nous détaillons ici.

2. L'Inventaire des Actifs

L'erreur est de sortir un export GLPI de 5000 lignes avec chaque clavier et écran. C'est inutile. Vous devez regrouper.

L'ISO 27005 nous demande de lier les Actifs Supports aux Actifs Primaires. La mécanique de liaison :

Un client ne vous paie pas pour votre serveur Linux (**Actif Support**).

Il vous paie pour le service de "Traitement des commandes" (**Actif Primaire**) qui tourne dessus. Si le serveur brûle, c'est le processus de commande qui s'arrête.

Votre liste d'actifs doit ressembler à ça :

- Processus RH (Actif Primaire)
 - Repose sur : Application SAP (Support Logiciel)
 - Repose sur : Serveur Dell R740 (Support Matériel)
 - Repose sur : Admin Système (Support Humain)
- Données Clients (Actif Primaire)
 - Repose sur : Base de données CRM (Support Données)
 - Repose sur : Hébergement AWS (Support Cloud)

Créez une liste d'actifs supports majeurs regroupés par familles (Matériel, Logiciel, Humain, Lieux, Prestataires). Pas plus.

3. Identifier les Menaces : Utilisez les "Cheat Sheet"

Pour construire des scénarios de risque crédibles et acceptés par les auditeurs, ne réinventez pas la roue. Appuyez-vous sur les référentiels standards du marché :

1. MITRE ATT&CK : La référence absolue pour les menaces techniques. Utilisez-la pour décrire des modes opératoires précis (Ransomware, Phishing, Mouvement Latéral) dans vos scénarios opérationnels.

2. Les Bases de Connaissances EBIOS RM (ANSSI) : Indispensable pour structurer les menaces stratégiques et identifier les "sources de risques" (Concurrents, Cybercriminels, Saboteurs).

3. OWASP Top 10 : La bible pour les risques spécifiques aux applications Web.

Pour chaque actif, passez le catalogue en revue et posez la question : "Est-ce possible ici ?"

Les menaces se classent en 3 familles. Vous devez en avoir de chaque catégorie :

- **Adversarielles** (Intentionnelles) : Quelqu'un vous veut du mal.
 - Exemples : Vol de matériel, espionnage industriel, ransomware, sabotage par un employé mécontent (Insider threat).
- **Accidentelles** (Erreur humaine/Technique) : Pas de méchant, juste de la malchance ou de l'incompétence.
 - Exemples : Erreur de configuration (la cause n°1 des fuites Cloud), suppression de base de données, panne disque dur, bug logiciel.
- **Environnementales** (Force majeure) : La nature se déchaîne.
 - Exemples : Incendie, inondation, coupure électrique, canicule (panne clim).

4. Identifier les Vulnérabilités : Où est la faille ?

C'est ici que l'analyse devient utile. Une menace sans vulnérabilité n'est pas un risque, c'est juste un bruit de fond.

Pour chaque couple Actif/Menace, demandez-vous : "Pourquoi suis-je faible face à ça ?"

- Scénario : Menace = Vol de PC portable.
 - Vulnérabilité A : Les disques durs ne sont pas chiffrés. (Risque élevé de fuite de données).
 - Vulnérabilité B : Les disques sont chiffrés avec Bitlocker. (Risque faible, on perd juste le matériel).

La vulnérabilité est souvent l'absence de contrôle.

- Menace : Incendie -> Vulnérabilité : Pas d'extincteurs automatiques.
- Menace : Phishing -> Vulnérabilité : Pas de formation des employés.
- Menace : Intrusion -> Vulnérabilité : Mots de passe faibles (admin/admin).

Action : C'est le moment de lister vos vulnérabilités. Si vous les cachez, vous ne pourrez pas demander de budget pour les corriger plus tard.

5. Formaliser le Scénario de Risque

Vous avez vos ingrédients. Maintenant, écrivez la phrase. C'est ce que vous mettrez dans votre registre Excel ou votre logiciel GRC (par exemple CISO Assistant - Gratuit).

Un scénario de risque complet doit identifier les conséquences sur le triptyque DIC (Disponibilité, Intégrité, Confidentialité).

Structure type d'un scénario valide :

"Il existe un risque de Perte de **Confidentialité/Disponibilité/Intégrité** d'un **Actif Primaire** dû à une **Menace** exploitant une **Vulnérabilité** sur **Actif Support**."

Exemple 1 (Ransomware) :

- *RISQUE* : Perte de Disponibilité et d'Intégrité des données comptables.
- *SCENARIO* : Un cybercriminel (Menace) envoie un malware exploitant une faille RDP non patchée (Vulnérabilité) sur le Serveur Compta (Actif Support), chiffrant ainsi toute la base (Actif Primaire).
- *CONSEQUENCE METIER* : Impossibilité de facturer pendant 5 jours, perte de trésorerie.

Exemple 2 (Vol) :

- *RISQUE* : Perte de Confidentialité des données clients.
- *SCENARIO* : Un voleur (Menace) profite de l'absence de câble antivol (Vulnérabilité) pour dérober un PC portable (Actif Support) contenant la base CRM locale (Actif Primaire).
- *CONSEQUENCE* métier : Fuite de données RGPD, amende CNIL, perte de réputation.

6. Résumé du Chapitre

À la fin de cette étape, vous devez avoir un tableau (votre "Registre des Risques Bruts") contenant 20 à 50 lignes.

Chaque ligne raconte un scénario potentiel.

La Checklist de validation :

- Avez-vous couvert les actifs critiques ?
- Avez-vous des menaces Humaines, Techniques et Physiques ?
- Vos vulnérabilités sont-elles réelles et actuelles ?
- Avez-vous identifié le préjudice métier (Conséquence) pour chaque ligne ?

CHAPITRE 3 : L'ANALYSE ET L'ÉVALUATION DU RISQUE

Vous avez maintenant une liste d'une cinquantaine de scénarios catastrophes, mais si vous allez voir votre Direction en disant "Tout est urgent", vous n'aurez rien. Si tout est prioritaire, rien n'est prioritaire.

L'objectif de ce chapitre est de transformer une liste subjective en un classement mathématique. Vous devez passer du "Je pense que c'est grave" au "Le score de risque est de 16/16".

L'ISO 27005 divise cette étape en deux mouvements distincts :

- L'Analyse du Risque : Déterminer la valeur (Le Calcul).
- L'Évaluation du Risque : Comparer la valeur au seuil de tolérance (Le Verdict).

1. L'Analyse : Sortez les calculatrices (ou pas)

Comment note-t-on un risque ? Il existe deux écoles.

L'approche Quantitative

Vous essayez de mettre des euros sur tout.

- Formule : $ALE \text{ (Perte Annuelle Espérée)} = SLE \text{ (Coût unique)} \times ARO \text{ (Fréquence annuelle)}$.
- Exemple : Une panne coûte 10 000 € (SLE). Elle arrive 2 fois par an (ARO). Le risque vaut 20 000 €/an.
- Le problème : C'est génial pour les risques fréquents (panne disque), mais c'est du mensonge pour la cyber. Quelle est la probabilité exacte d'une attaque Ransomware cette année ? 10% ? 30% ? Personne ne sait.
- Mon conseil : Oubliez ça pour votre première certification. C'est trop long et indéfendable face à un auditeur qui grattera vos hypothèses.

L'approche Qualitative

Vous utilisez les échelles définies au Chapitre 1 (par exemple de 1 à 4). C'est simple, rapide et suffisant.

Pour chaque scénario de votre liste, vous devez attribuer deux notes.

A. Notez la Vraisemblance

C'est le domaine de l'expert technique (Vous). Regardez vos Vulnérabilités. Plus la faille est béante, plus la vraisemblance est haute.

- Scénario : Intrusion Wifi.
- Cas A : Wifi ouvert sans mot de passe. -> Vraisemblance 4/4 (C'est certain que ça arrivera).
- Cas B : Wifi WPA2 Enterprise avec certificats. -> Vraisemblance 1/4 (Très difficile).

B. Notez l'Impact

C'est le domaine du Métier. Interdiction formelle pour l'informaticien de noter l'impact seul. Vous ne savez pas combien coûte une heure d'arrêt de la chaîne de production. Le Directeur Financier, lui, le sait.

- Méthode : Faites un atelier "Risk Assessment". Prenez la liste des scénarios, et demandez aux responsables métiers : "Si ce service coupe pendant 24h, on perd combien ?"
- Si la réponse est "On s'en fiche", notez Impact 1.
- Si la réponse est "On met la clé sous la porte", notez Impact 4.

Le Calcul du Niveau de Risque :

La méthode la plus courante est la multiplication.

Niveau de Risque = Vraisemblance x Impact

- Exemple Phishing : Vraisemblance (3) x Impact (3) = 9.
- Exemple Météorite : Vraisemblance (1) x Impact (4) = 4.

2. L'Évaluation

Vous avez un chiffre. Et ensuite ?

Un "9", est-ce grave ? Pour le savoir, vous devez projeter ce chiffre sur votre Matrice d'Acceptation (définie au Chapitre 1).

C'est l'étape de l'Évaluation (Risk Evaluation).

La Matrice de Chaleur (Heatmap)

Imaginez un tableau.

- Axe X : Impact (1 à 4).
- Axe Y : Vraisemblance (1 à 4).

Cela crée des zones de couleur :

- Zone Verte (Score 1 à 4) : Risque faible.
- Zone Jaune/Orange (Score 5 à 9) : Risque modéré.
- Zone Rouge (Score 10 à 16) : Risque critique.

La Décision binaire

L'évaluation sert à trier les risques en deux tas :

- Les Risques Acceptables : Ils tombent dans le vert. On ne fait rien. On documente juste qu'on a vu le risque et qu'on dort bien avec.
- Les Risques Non-Acceptables : Ils tombent dans l'orange ou le rouge. Il FAUT les traiter. L'option "ne rien faire" est interdite par la norme (sauf signature dérogatoire de la direction, voir Chapitre 4).

Le Rôle du Propriétaire du Risque (Risk Owner)

Qui valide que le risque n°12 est "Inacceptable" ? Ce n'est pas vous. C'est le Propriétaire du Risque.

Si le risque concerne les données RH, c'est le DRH. Si c'est toute l'entreprise, c'est le PDG. Vous devez obtenir leur validation formelle écrite sur le classement.

3. Impact vs Probabilité

Soyez vigilants sur un point crucial : Mathématiquement, 4×1 est égal à 1×4 .

- Risque A (Météorite) : Impact Catastrophique (4) x Vraisemblance Impossible (1) = Score 4.
- Risque B (Imprimante en panne) : Impact Nul (1) x Vraisemblance Quotidienne (4) = Score 4.

Si vous suivez bêtement les maths, ces risques sont égaux. Dans la réalité, c'est faux. Un risque à Impact 4 (Météorite, Incendie majeur, Ransomware total) peut tuer l'entreprise en un coup, même s'il est rare.

Un risque à Impact 1 est juste une nuisance, même s'il arrive tous les jours.

En cas d'égalité de score, donnez toujours la priorité à l'Impact. Pourquoi ? Parce que l'estimation de la vraisemblance est souvent une devinette (vous pouvez vous tromper sur la fréquence du piratage), alors que l'impact est une certitude (si ça brûle, c'est 1M€ de perte).

4. Livrable : Le Registre des Risques Classé

À la fin de ce chapitre, votre fichier Excel a changé de visage. C'est un plan de bataille.

Il doit ressembler à ceci (trié par score décroissant) :

ID	Scénario	Vraisemblance	Impact	Score	Zone	Priorité
R-01	Ransomware via Email	3	4	12	ROUGE	1
R-02	Vol de PC non chiffré	3	3	9	ORANGE	2
R-03	Panne disque Serveur	2	2	4	VERT	•
R-04	Chute de météorite	1	4	4	VERT	•

Analyse immédiate :

- Vous avez identifié vos cibles prioritaires (R-01 et R-02).
- Vous avez justifié pourquoi vous n'allez pas dépenser un centime pour le risque R-03 et R-04 (ils sont acceptables).

C'est ici que vous gagnez votre crédibilité. Vous n'êtes plus celui qui demande de l'argent pour "la sécurité". Vous êtes celui qui demande un budget pour traiter le Risque R-01 qui menace la survie de l'entreprise. Maintenant que nous savons quels sont les risques prioritaires, il est temps de choisir les armes.

CHAPITRE 4 : LE TRAITEMENT DU RISQUE

Vous avez identifié vos ennemis. Vous les avez classés. Votre "Registre des Risques" affiche désormais des lignes rouges (Risques Inacceptables) qui clignotent.

Si vous vous arrêtez là, vous n'avez fait que de l'observation. L'objectif de ce chapitre est la prise de décision. Pour chaque risque rouge, vous devez choisir une stratégie, l'appliquer, et prouver qu'elle fonctionne. C'est l'étape du Traitement du Risque (Risk Treatment).

1. Les 4 Options Stratégiques

Face à un risque inacceptable (ex : un Ransomware qui bloque l'usine), vous n'avez que 4 choix possibles. Ce sont les options de l'ISO 27005, vous devrez justifier chaque choix.

Option A : Modification du Risque (La Réduction)

C'est le choix que vous ferez dans 90% des cas.

- Le principe : Le risque est trop haut, on va le baisser en ajoutant des mesures de sécurité (Contrôles).
- Mécanique : On agit soit sur la Vraisemblance (empêcher l'attaque), soit sur l'Impact (limiter la casse).
- Exemple :
 - *RISQUE* : Perte de données sur PC portable volé.
 - *ACTION* : Chiffrement du disque dur (Bitlocker).
 - *RESULTAT* : La probabilité de vol reste la même (on vole toujours le PC), mais l'impact "Fuite de données" tombe à zéro. Le risque passe de Rouge à Vert.

Option B : Partage du Risque (Le Transfert)

Vous ne pouvez pas empêcher le risque, alors vous payez quelqu'un d'autre pour payer à votre place.

- Le principe : Déplacer l'impact financier ou juridique vers un tiers.
- Attention : On transfère les conséquences financières, mais on ne transfère jamais la responsabilité. Si vos données fuient chez votre sous-traitant, c'est VOTRE réputation qui est détruite.
- Exemple : Souscrire une Cyber-Assurance pour payer la rançon ou les frais juridiques. Utiliser un hébergeur Cloud certifié (AWS/Azure) pour ne plus gérer le risque "Incendie du Datacenter".

Option C : Évitement du Risque (La Solution Radicale)

Le risque est trop grand, et aucune mesure ne coûte assez peu cher pour le réduire.

- Le principe : On supprime purement et simplement l'activité qui génère le risque. On coupe le bras pour sauver le corps.
- Exemple :
 - *RISQUE* : Votre vieux serveur FTP de 2003 est une passoire impossible à sécuriser.
 - *ACTION* : On éteint le serveur. On arrête de proposer ce service aux clients.
 - *RESULTAT* : Risque = 0. (Mais opportunité business = 0 aussi).

Option D : Maintien du Risque (L'Acceptation)

C'est l'option la plus dangereuse et la plus surveillée par les auditeurs.

- Le principe : Le risque est Rouge. On le sait. Mais le coût pour le réduire est supérieur à la perte potentielle, ou nous n'avons pas le budget cette année. On décide consciemment de ne rien faire.
- La règle absolue : Le RSSI ne peut pas signer ça. Seule la Direction Générale peut signer une dérogation d'acceptation de risque élevé.
- Exemple : Le risque de chute d'un avion sur l'usine. C'est catastrophique (Rouge), mais on ne va pas déménager l'usine ni installer un dôme en béton. On accepte.

2. Sélectionner les Mesures (Annexe A)

Vous avez choisi l'option Modification (Réduction). Très bien. Mais comment on modifie ?
On ouvre le catalogue de l'Annexe A de l'ISO 27001 (détaillée dans l'ISO 27002). C'est votre menu : Il y a 93 plats (Contrôles). Pour chaque risque, piochez les contrôles pertinents.

- Scénario : Risque d'intrusion sur le réseau Wi-Fi.
- Traitement choisi :
 - Plat n°1 : Contrôle 8.20 (Sécurité des réseaux) -> Ségrégation du réseau Invité.
 - Plat n°2 : Contrôle 5.15 (Contrôle d'accès) -> Authentification Radius pour les employés.

Le Plan de Traitement des Risques (PTR)

C'est votre plan de projet. Pour chaque risque, vous devez définir :

- L'option choisie (Modifier).
- Les contrôles sélectionnés (8.20, 5.15).
- Le responsable de l'action (Admin Réseau).
- La date limite (30 juin).
- Le budget (Ex : 5000 € pour les bornes Wifi).

Sans PTR, votre analyse de risques est un simple document Excel. L'auditeur demandera : "Montrez-moi votre PTR et l'avancement des actions."

3. Le Risque Résiduel

C'est le concept central de l'ISO 27005. Le risque zéro n'existe pas. Même avec le meilleur pare-feu, le meilleur antivirus et la meilleure formation, il reste une infime chance de se faire pirater. C'est le Risque Résiduel.

La mécanique de calcul :

- Risque Brut (Inhérent) : Avant traitement. (Ex : Score 16 - Rouge).
- Traitement : J'installe un Antivirus.
- Risque Résiduel : Après traitement. La probabilité baisse. (Ex : Score 4 - Vert).

L'Acceptation Formelle :

Une fois le traitement appliqué théoriquement, vous devez vérifier si le Score Résiduel tombe dans la Zone Verte de votre matrice.

- Si OUI : C'est fini. Le Risk Owner signe qu'il accepte ce résiduel.
- Si NON : Si malgré tous les contrôles, le risque reste Orange/Rouge (ex : risque nucléaire, risque bancaire systémique), la Direction doit signer une dérogation spéciale ou envisager l'Évitement.

Ne trichez pas sur le résiduel. Ne dites pas "Antivirus installé = Risque 0". Dites "Risque faible".

4. Le Lien avec la SoA (Déclaration d'Applicabilité)

C'est ici que tout se connecte. La SoA (**Statement of Applicability**) est le document qui fait le pont entre votre Risque (ISO 27005) et votre Conformité (ISO 27001).

Chaque fois que vous sélectionnez un contrôle (ex : 8.7 Protection contre les malwares) pour traiter un risque, vous devez aller dans votre fichier SoA et cocher la case :

- Contrôle 8.7 : Applicable.
- Justification : Requis pour traiter le Risque R-01 (Ransomware).
- Statut : En cours (Voir PTR).

Si un contrôle de l'Annexe A n'est utilisé pour aucun risque, ni exigé par la loi, ni par un contrat, alors vous pouvez le marquer "Non Applicable" dans la SoA. C'est la seule façon de justifier une exclusion.

Résumé du Chapitre

La boucle est bouclée :

- J'ai un Risque Rouge.
- Je décide de le Modifier.
- Je sélectionne des mesures dans l'Annexe A.
- Je planifie leur mise en œuvre dans le PTR (Qui/Quand/Budget).
- Je calcule le Risque Résiduel et je vérifie qu'il est Vert.
- Je mets à jour la SoA pour officialiser le tout.

À ce stade, vous avez fait 90% du travail d'un Risk Manager.

CHAPITRE 5 : COMMUNICATION ET SURVEILLANCE

Vous avez identifié, analysé, évalué et traité vos risques. Vous avez un fichier Excel, une SoA signée et un PTR validé.

C'est maintenant que le vrai travail commence. Un système de gestion des risques est une denrée périssable. La menace évolue (IA, quantique, géopolitique), la technologie change (Cloud, SaaS), et votre entreprise change (rachats, nouveaux produits).

Une analyse de risque statique est une simple photographie.

L'ISO 27005 ne certifie pas une photo, elle certifie un film. Ce chapitre couvre les processus transverses qui doivent tourner en permanence : la Communication et la Surveillance.

1. Communication et Consultation

L'erreur principale du Risk Manager est de travailler seul. Si vous remplissez les colonnes "Impact" et "Vraisemblance" tout seul dans votre bureau, votre analyse est caduque. Elle est biaisée par votre vision technique et déconnectée de la réalité business. L'ISO 27005 impose la Consultation à chaque étape.

Pourquoi consulter ?

- Pour la vérité terrain : Vous pensez que le risque "Panne Serveur" est critique. L'admin sys vous dira qu'il a mis en place un cluster haute dispo indestructible. Vous surestimez le risque.
- Pour la vérité business : Vous pensez que l'arrêt de l'application "Cantine" est négligeable. Le DRH vous dira que cela provoquera une émeute sociale immédiate. Vous sous-estimez l'impact.
- Pour l'adhésion (Buy-in) : Si vous imposez une mesure de sécurité (ex : MFA obligatoire) sans expliquer le risque qu'elle couvre, les utilisateurs la contourneront. Si vous leur expliquez "C'est pour éviter le vol de vos salaires", ils l'accepteront.

La Règle d'Autorité

Ne présentez jamais une analyse de risques finie à la direction. Présentez une analyse construite avec eux. Quand le Directeur Financier voit le risque "Fraude au virement" en zone rouge, il ne doit pas être surpris, car c'est lui qui vous a donné le montant de l'impact financier la semaine dernière.

2. La Surveillance

Comment savoir si votre plan de traitement fonctionne ? Vous ne pouvez pas attendre le piratage pour vérifier si le pare-feu est efficace. Vous devez mettre en place des capteurs. Ce sont les KRI (**Key Risk Indicators**).

KRI vs KPI : Ne confondez pas

- **KPI (Performance)** : "Est-ce que le système marche bien ?" (Ex : Disponibilité du serveur = 99.9%).
- **KRI (Risque)** : "Est-ce que le danger approche ?" (Ex : Nombre de tentatives d'intrusion bloquées par heure).

Vous devez définir des seuils d'alerte.

- *SCENARIO* : Risque de non-conformité des postes de travail (Manque de patches).
- *KRI* : % de PC n'ayant pas reçu de mise à jour de sécurité depuis > 30 jours.
- *SEUIL VERT* : < 5%.
- *SEUIL ORANGE* : 5% à 10%.
- *SEUIL ROUGE* : > 10%.

Si l'indicateur passe au rouge, vous n'attendez pas la revue annuelle. Vous déclenchez une action corrective immédiate. C'est cela, le "pilotage par les risques".

Exemples de KRI :

- Risque Phishing : % d'utilisateurs cliquant sur un lien lors des tests trimestriels.
- Risque Fuite de données : Nombre d'alertes DLP (Data Loss Prevention) générées par semaine.
- Risque Fournisseur : Nombre de sous-traitants n'ayant pas renvoyé leur attestation de sécurité annuelle.

3. La Revue

Votre registre des risques n'est pas gravé dans le marbre. Il doit être mis à jour. Mais quand ?
Il y a 4 déclencheurs (Triggers) officiels que vous devez connaître :

A. La Revue Planifiée (Le Minimum Syndical)

Au minimum, une fois par an (souvent avant l'audit de surveillance).
On relit tout. On vérifie si les menaces ont changé, si les actifs sont toujours là.

- Question classique : "Ce risque est en zone rouge depuis 3 ans, pourquoi ?"
- Réponse : Si vous n'avez rien fait en 3 ans, ce n'est plus un risque, c'est une négligence acceptée.

B. Le Changement Majeur (Major Change)

C'est le déclencheur le plus important.

- Vous migrez vos serveurs locaux vers AWS ? Nouvelle analyse. (Les risques physiques disparaissent, les risques de config Cloud apparaissent).
- Vous rachetez une entreprise ? Nouvelle analyse.
- Vous lancez une nouvelle application mobile ? Nouvelle analyse.
- L'intégration de la sécurité dans les projets (Privacy by Design) impose de faire l'analyse de risques avant la mise en production, pas après.

C. L'Incident Majeur

Vous venez de subir un Ransomware alors que vous aviez classé ce risque en "Faible" (Vert) ?

Vous vous êtes trompé. Votre analyse était fausse.

L'incident est la preuve du réel. Vous devez immédiatement rouvrir le dossier, réévaluer la Vraisemblance à 4/4 (puisque c'est arrivé) et corriger le tir.

D. Le Changement de Contexte Externe

Le monde change.

- Nouvelle loi (AI Act, DORA, NIS2) : De nouveaux risques de conformité apparaissent.
- Nouvelle menace technologique (Ordinateur Quantique cassant le chiffrement actuel) : Vos mesures actuelles deviennent obsolètes.

4. Le Reporting à la Direction

Le dernier maillon de la chaîne est le rapport au Top Management. Rappelez-vous : le but ultime de l'ISO 27005 est d'aider la direction à prendre des décisions.

Ne leur envoyez pas le fichier Excel de 500 lignes. Ils ne le liront pas.

Produisez une synthèse d'un page contenant :

- La Heatmap (Matrice) Comparée :
 - "L'année dernière, nous avons 12 risques Rouges."
 - "Cette année, après investissement, nous n'en avons plus que 3."
 - Message : Votre argent a été bien utilisé.
- Le Top 5 des Risques Résiduels :
 - "Voici les 5 scénarios qui peuvent encore nous tuer aujourd'hui."
 - "Acceptez-vous de vivre avec ?" (Signature requise).
- Les Besoins en Ressources :
 - "Pour traiter le dernier risque rouge (Obsolescence ERP), j'ai besoin de 50k€."

C'est à ce moment précis que vous cessez d'être un technicien coûteux pour devenir un partenaire stratégique qui protège la valeur de l'entreprise.

CONCLUSION

Vous avez parcouru les 5 étapes.

- **Cadrage** : Vous avez défini les règles du jeu.
- **Identification** : Vous avez trouvé les monstres.
- **Analyse** : Vous avez trié l'urgent du futile.
- **Traitement** : Vous avez choisi vos armes et agi.
- **Surveillance** : Vous gardez les yeux ouverts.

Ce livre vous a donné les cartes, mais c'est à vous de marcher sur le terrain. La vraie gestion des risques ne s'apprend pas dans les livres. Elle s'apprend en négociant un budget avec un DAF sceptique. Elle s'apprend en expliquant à un administrateur système pourquoi il doit changer ses habitudes. Elle s'apprend en prenant des décisions difficiles quand tous les voyants sont au rouge.

LISTE DES DOCUMENTS A PRODUIRE

Voici votre Master Checklist.

Ce tableau résume l'intégralité des livrables exigés par la norme, classés par ordre chronologique de création. C'est votre feuille de route opérationnelle. La règle est simple :

- Si vous pouvez poser ces 12 documents sur la table, vous êtes bien partis.
- S'il en manque un seul, vous êtes non-conforme.

Phase	Ordre	Document (Livrable)	Ce qui est attendu (Concrètement)	Justification / Norme (Pourquoi)	Formules & Contenu Critique	Destinataire / Signataire
1. Cadrage	1	Politique de Gestion des Risques	Un document Word/PDF (5-10 pages) formalisant les règles du jeu : qui décide, quand et comment.	Exigence ISO 27001 (6.1.2). Prouve la répétabilité.	Rôles (Risk Owner vs Manager), Périodicité, Références réglementaires.	Auditeur / Direction
1. Cadrage	2	Échelles de Notation (Critères)	Deux tableaux de référence : un pour l'Impact (seuils financiers/temps) et un pour la Vraisemblance (fréquence).	Assure l'objectivité et évite le flou artistique.	Impact (I) : 1 à 4 (en €/Temps) Vraisemblance (V) : 1 à 4 (Fréquence)	Direction (Validation)

1. Cad rag e	3	Matrice d'Accep tation (Vierge)	Une grille colorée (ex : 4x4 ou 5x5) définissant visuellement les zones acceptables vs critiques.	Fixe l'appéte nce au risque avant de voir les résultats .	Zones : Vert (Acceptable), Orange (A surveiller), Rouge (Inacceptable).	Directi on (Valida tion)
2. App réci atio n	4	Inventa ire des Actifs	Un onglet Excel listant les Actifs Supports (Serveurs, Appli, Locaux) et les liant aux Processus Métiers.	Base de l'approc he. On ne protège pas ce qu'on ignore.	Lien : Actif Primaire (Métier) <-> Actifs Supports (Tech).	Risk Manag er / Métier s
2. App réci atio n	5	Registr e des Risques (Brut)	Un grand tableau Excel. 1 ligne = 1 Scénario. Doit montrer le score AVANT traitement.	Centralis e l'identifi cation et le calcul.	Scénario = Menace + Vulnérabilité + Actif Score Brut (Rb) = V x I	Risk Manag er
2. App réci atio n	6	Cartogr aphie (Heatm ap Rempli e)	Un graphique ou une grille positionnan t les risques identifiés (points) selon leur score.	Permet la prise de décision rapide ("Vue Hélicopt ère").	Positionnement des risques bruts sur la matrice définie en étape 3.	ComEx / Directi on
3. Trai tem ent	7	Plan de Traitem ent (PTR / RTP)	Un plan d'action (Excel/Proj ect). Liste les tâches, responsable s, échéances et coûts.	Exigence ISO 27001 (6.1.3). Transforme l'analyse en action.	Option (Modif/Partage/ Evit/Maintien) + Contrôle Annexe A + Budget + Date.	DSI / RSSI / Projets

3. Traitement	8	Déclaration d'Applicabilité (SoA)	Un tableau des 93 contrôles. Colonnes obligatoires : Applicable (Oui/Non) et Justification .	Lien juridique entre Risque (27005) et Audit (27001).	SI (Contrôle dans PTR) = Applicable. Justification OBLIGATOIRE pour chaque exclusion.	Auditeur
3. Traitement	9	Registre des Risques Résiduels	Le même tableau que le Brut, mais avec les nouveaux scores projetés APRÈS mesures.	Prouve l'efficacité théorique des investissements.	Score Résiduel (Rr) = (V - gain) x (I - gain) Objectif : Rr < Seuil Rouge	Risk Manager
3. Traitement	10	Acceptation Formelle des Risques	Un document signé (ou email formel archivé) par le Risk Owner validant le niveau de risque final.	Transfert de responsabilité légale vers le Business .	"Je soussigné, [Nom], accepte le risque résiduel tel que défini..."	Risk Owner (CRITIQUE)
4. Surveillance	11	Tableau de Bord KRI	Un tableau de bord avec des seuils d'alerte (Vert/Orange/Rouge) sur des métriques clés.	Prouve que l'analyse est vivante (Monitoring).	SI (KRI > Seuil Alerte) ALORS (Action Corrective).	RSSI / Équipes Ops

4. Surveillance	12	Rapport de Revue de Direction	Une slide PPT ou un mémo d'une page résumant la situation pour décider du budget.	Justification budgétaire et réaligement stratégique.	Comparatif N-1 vs N. Top 5 Risques Résiduels. Budget demandé.	Direction Générale
------------------------	----	-------------------------------	---	--	---	--------------------

GLOSSAIRE

A

Actif (Asset)

Tout élément ayant de la **valeur** pour l'organisation.

- **Actif Primaire** : L'information ou le processus métier vital qui a de la **valeur intrinsèque** (ex : Base Clients, Processus de Paie).
- **Actif Support** : Le composant **technique, physique ou humain** sur lequel repose l'actif primaire (ex : Serveur, Local, Admin Sys). **L'analyse technique se fait ici.**

Acceptation (Décision)

Décision du **Risk Owner** de **ne pas traiter** un risque.

- **Contexte** : Soit parce que le risque est **déjà faible** (Zone Verte), soit par **dérogation spéciale** de la direction si le coût du traitement est prohibitif.

Adversarielle (Menace)

Type de menace **intentionnelle** où un **acteur malveillant** (humain) cible l'organisation (ex : Hacker, Espionnage, Sabotage).

Accidentelle (Menace)

Type de menace **sans intention de nuire**, résultant d'une **erreur** ou d'une **défaillance** (ex : Erreur de l'admin, Bug logiciel).

Annexe A (ISO 27001)

La liste normative des **93 contrôles** de sécurité. C'est le "**Menu**" dans lequel on pioche pour traiter les risques. Détaillée par l'ISO 27002.

Analyse du Risque

Étape **mathématique** consistant à déterminer le niveau du risque en combinant la **Vraisemblance** et l'**Impact**. Peut-être **Qualitative** (Score 1-4) ou **Quantitative** (Euros).

Appréciation du Risque (Risk Assessment)

Le processus global qui englobe trois étapes successives : **Identification + Analyse + Évaluation**.

Approche par les Actifs

Méthode d'identification consistant à **lister tout le matériel/logiciel** pour trouver les failles. **Exhaustive mais laborieuse.**

Approche par les Événements

Méthode d'identification consistant à partir des **scénarios de crise** redoutés par la direction. **Rapide et orientée business.**

C

Contrôle (Mesure)

Toute action (Technique, Organisationnel, Physique) visant à **modifier un risque.**

Critères d'Acceptation

Seuils définis par la direction pour déterminer si un risque est **tolérable ou non.** Matérialisés par la **Matrice de Chaleur.**

Critères d'Impact

Échelle de notation de la **gravité** (ex : 1 = <1k€, 4 = >100k€). Doit être validée par le **Business, pas l'IT.**

Critères de Vraisemblance

Échelle de notation de la **fréquence** (ex : 1 = Jamais, 4 = Mensuel).

D

Déclencheur (Trigger)

Événement qui **oblige à refaire une analyse** de risques (ex : Changement d'infrastructure, Rachat, Incident de sécurité, Nouvelle loi).

DIC (Disponibilité, Intégrité, Confidentialité)

Les **trois critères** de sécurité. Un scénario de risque doit spécifier **lequel est touché** (ex : "Perte de Confidentialité").

E

Environnementale (Menace)

Type de menace liée à des **événements naturels** ou **physiques** majeurs (ex : Incendie, Inondation, Coupure électrique).

Évaluation du Risque (Evaluation)

Comparaison du score calculé lors de l'Analyse avec les **Critères d'Acceptation** pour décider : "**On traite**" ou "**On accepte**".

Évitement

Stratégie de traitement radicale : **stopper l'activité** pour **supprimer le risque** (ex : Éteindre un service).

I

Identification

Processus de recherche et de listage des risques (**Actifs + Menaces + Vulnérabilités**).

Impact (Conséquence)

Le **dégât subi par le métier**. Se mesure en argent, temps, image ou légal.

ISO 27001 (Clause 6.1.2)

L'exigence normative ("**La Loi**") qui oblige l'entreprise à réaliser une appréciation des risques.

ISO 27005

La norme ("**Le Guide**") qui fournit la méthodologie pour satisfaire l'exigence de la 27001.

K

KPI (Key Performance Indicator)

Mesure de la performance **passée** (ex : Disponibilité 99%).

KRI (Key Risk Indicator)

Indicateur d'alerte sur un risque **futur** (ex : Augmentation des tentatives de phishing). Sert à la **Surveillance**.

M

Maintien

Voir **Acceptation**.

Matrice de Chaleur (Heatmap)

Outil graphique (**Vert/Orange/Rouge**) croisant **Impact** et **Vraisemblance** pour visualiser les priorités.

Menace (Threat)

Cause potentielle d'un incident. **Externe** à l'actif. L'élément **déclencheur** du scénario.

Modification (Réduction)

Stratégie de traitement consistant à appliquer des contrôles pour **baisser le score** du risque.

P

Partage (Transfert)

Stratégie de traitement consistant à déplacer l'impact **financier** vers un tiers (Assurance). Attention : la **responsabilité ne se transfère pas**.

Propriétaire du Risque (Risk Owner)

Directeur ou Responsable Métier ayant l'**autorité** pour **accepter** le risque résiduel. Ce n'est **pas le RSSI**.

PTR (Plan de Traitement des Risques)

Document de gestion de projet (**Qui/Quoi/Quand/Budget**) pour mettre en œuvre les contrôles décidés.

Q

Qualitative (Analyse)

Méthode utilisant des échelles **descriptives** (Faible/Moyen/Fort). Recommandée pour démarrer.

Quantitative (Analyse)

Méthode utilisant des données **chiffrées précises** et financières. **Difficile à justifier** en cyber.

R

Registre des Risques

Le fichier (souvent Excel) central qui liste **tous les scénarios**, leurs scores et leurs propriétaires.

Risque

Effet de l'**incertitude** sur les objectifs.

Formule ISO 27005 : Scénario où une **Menace** exploite une **Vulnérabilité** sur un **Actif**.

Risque Brut (Inhérent)

Le niveau de risque évalué **avant** la prise en compte des mesures de traitement supplémentaires.

Risque Résiduel

Le niveau de risque qui subsiste **après** le traitement. Doit être **formellement accepté** par le Risk Owner.

Risk Manager

L'expert (Vous) qui **facilite** le processus, propose la méthode et anime les ateliers. Il **ne décide pas** de l'acceptation.

S

Scénario de Risque

L'histoire complète du danger : **Cause** (Menace) -> **Faille** (Vulnérabilité) -> **Cible** (Actif) -> **Effet** (Impact).

SoA (Statement of Applicability / DDA)

Document "**Déclaration d'Applicabilité**". Liste les 93 contrôles, dit s'ils sont applicables, et **justifie les exclusions**. Lien vital entre **Risque et Audit**.

Surveillance (Monitoring)

Processus continu de vérification des indicateurs (**KRI**) et des changements de **contexte** pour garder l'analyse à jour.

V

Vraisemblance (Likelihood)

Estimation de la **probabilité** ou de la **fréquence** d'apparition d'un risque.

Vulnérabilité

Faiblesse intrinsèque d'un actif (absence de mesure, faille logicielle, erreur humaine) exploitable par une menace. **Sans vulnérabilité, pas de risque.**